

PRAXIS-CHECKLISTE · DACH 2026

EU AI Act 2026 – Praxis-Checkliste

Was Unternehmen wissen müssen – kompakt, branchenneutral,
ohne Marketing-Geschwurbel.

ERSTELLT

24. Mai 2026

QUELLE

aevum-system.de

EU AI Act 2026 – Praxis-Checkliste für Unternehmen

Was du als Unternehmer in DACH 2026 zur EU-Verordnung über Künstliche Intelligenz wissen MUSST. Konkret. Kompakt. Branchenneutral.

Was ist der EU AI Act?

Der **EU AI Act** (Verordnung (EU) 2024/1689) ist die weltweit erste umfassende gesetzliche Regulierung von Künstlicher Intelligenz. Sie wurde im Juni 2024 verabschiedet und tritt **stufenweise zwischen 2025 und 2027** in Kraft.

Die Verordnung gilt **direkt** in allen EU-Mitgliedsstaaten – auch für Unternehmen ausserhalb der EU, wenn ihre AI-Systeme in der EU genutzt werden oder Ergebnisse EU-Bürger betreffen (Markortprinzip, analog zur DSGVO).

Das Gesetz folgt einem **risikobasierten Ansatz**: Je höher das Risiko eines AI-Systems für Grundrechte, Sicherheit oder Gesundheit, desto strenger die Pflichten. Verbotene Systeme sind seit Februar 2025 nicht mehr erlaubt; Transparenz-Pflichten für Chatbots und generative AI gelten ab August 2025; die strengen Anforderungen für sogenannte High-Risk-Systeme greifen voraussichtlich ab August 2026.

Strafen können bis zu **35 Mio. Euro oder 7 % des weltweiten Jahresumsatzes** betragen – je nachdem, welcher Betrag höher ist.

Risiko-Stufen – wo stehst du?

Die Verordnung unterscheidet vier Kategorien. Welche trifft auf deine AI zu?

- **Verbotene AI-Systeme** – seit 02/2025 nicht mehr zulässig.

Beispiele: Social Scoring durch Behörden, manipulative AI gegen Verbraucher, biometrische Echtzeit-Identifizierung im öffentlichen Raum (mit eng definierten Ausnahmen).

- **High-Risk-Systeme** – strenge Pflichten ab voraussichtlich 08/2026.

Beispiele: AI im Recruiting, Kredit-Scoring, kritische Infrastruktur, Bildungsentscheidungen, Strafverfolgung, medizinische Diagnostik.

- **Limited-Risk-Systeme** – Transparenz-Pflicht ab 08/2025.

Beispiele: Chatbots, Emotion-Recognition, Deepfakes, AI-generierte Inhalte.

- **Minimal-Risk-Systeme** – kaum Pflichten.

Beispiele: Spam-Filter, AI in Computerspielen, einfache Empfehlungssysteme.

Die meisten Unternehmen in DACH werden hauptsächlich mit **Limited-Risk**-Anforderungen konfrontiert sein (Chatbots, generative AI im Marketing). Wer AI in HR, Finanzen oder kritischer Infrastruktur einsetzt, fällt unter **High-Risk**.

Checkliste – pro Use-Case

A. AI in Customer-Interaktion (Helpbot, Voice-AI, Email-Auto-Reply)

Risiko-Stufe: Limited-Risk **Geltung:** Transparenz-Pflicht ab 08/2025

☐ **Kennzeichnung als AI** – Nutzer muss erkennen können, dass er

mit einem KI-System interagiert (Pflicht für Limited-Risk).

☐ **DSGVO-konforme Datenerhebung** — Rechtsgrundlage, Zweckbindung,

Speicherdauer dokumentiert (DSGVO Art. 5, 6).

☐ **Audit-Log** der AI-Interaktionen für angemessenen Zeitraum

(üblich: 6 Monate, je nach Branche länger).

☐ **Eskalations-Pfad zu Mensch** für komplexe / kritische Anfragen.

☐ **Halluzinations-Sicherung** — die AI darf nicht über

rechtsverbindliche Themen oder kritische Entscheidungen eigenständig urteilen.

B. AI in HR / Recruiting

Risiko-Stufe: High-Risk (Anhang III der Verordnung) **Geltung:** Strenge Pflichten ab 08/2026

☐ **Bias-Audit dokumentiert** — Tests auf Diskriminierung pro

geschützter Gruppe (Geschlecht, Alter, Herkunft etc.).

☐ **Human-in-the-Loop** bei finalen Personalentscheidungen — die

AI darf nicht alleinige Grundlage für Einstellung/Ablehnung sein.

☐ **Conformity Assessment** vor Inbetriebnahme.

☐ **Risk Management System** kontinuierlich gepflegt.

☐ **Datenschutz-Folgenabschätzung (DSFA)** nach DSGVO Art. 35

durchgeführt.

☐ **Information an Bewerber** , dass AI im Prozess eingesetzt wird.

C. AI in Marketing / Content-Generation

Risiko-Stufe: Limited-Risk **Geltung:** Transparenz-Pflicht ab 08/2025

☐ **Deepfake-Kennzeichnung** — synthetisch erzeugte Inhalte mit

Personen-Imagery müssen erkennbar als künstlich markiert werden.

☐ **AI-Generierungs-Hinweis** bei generativen Inhalten

(Bild, Video, Text), die Verbraucher erreichen.

☐ **Copyright-Check für Trainingsdaten** — Urheberrechte beachten,

Opt-out-Signale respektieren (TDM-Vorbehalt nach UrhG §44b).

☐ **Klare Trennung** zwischen redaktionellem und AI-generiertem

Content in der Kommunikation.

D. AI in Finance / Lending

Risiko-Stufe: High-Risk **Geltung:** Strenge Pflichten ab 08/2026

☐ **Explainability** — Ablehnungen müssen für Betroffene

nachvollziehbar erklärt werden (auch DSGVO Art. 22).

☐ **Bias-Tests** pro geschützter Gruppe, dokumentiert.

☐ **Registrierung** in der EU-Datenbank für High-Risk-Systeme

(sobald operativ).

☐ **Cybersicherheit und Robustheit** des Modells nachgewiesen.

☐ **Konformitäts-Erklärung** durch Anbieter / Betreiber.

E. AI in Healthcare

Risiko-Stufe: High-Risk **Geltung:** Strenge Pflichten ab 08/2026 + sektorspezifisches Recht

☐ **MDR-Zertifizierung** falls als Medizinprodukt klassifiziert

(Medical Device Regulation (EU) 2017/745).

☐ **Klinische Studien-Dokumentation** für Validierung.

☐ **Notified Body-Approval** für höhere Risikoklassen.

☐ **Kompatibilität** zwischen AI-Act-Anforderungen und sektorspezifischem

Gesundheitsrecht prüfen.

Konsequenzen bei Verstoss

Die Verordnung sieht **gestaffelte Strafen** vor:

- **Bis zu 35 Mio. Euro ODER 7 % des weltweiten Jahresumsatzes** —

bei Einsatz verbotener AI-Systeme.

- **Bis zu 15 Mio. Euro ODER 3 % des Umsatzes** — bei Verstoss gegen

High-Risk-Pflichten oder Transparenz-Anforderungen.

- **Bis zu 7,5 Mio. Euro ODER 1,5 % des Umsatzes** — bei Falschangaben

gegenüber Behörden.

Je nach Verstoss greift der höhere Betrag. Für KMU und Start-ups gelten ggf. abgemilderte Sätze (Art. 99 Abs. 6 der Verordnung).

DSGVO-Verstöße kommen oben drauf — beide Regelwerke gelten parallel. Zusätzlich möglich: Marktverbot, Schadensersatz nach Zivilrecht, Reputationsschaden.

Quick-Check: Bist du betroffen?

Drei Fragen für eine erste Selbsteinschätzung:

1. ****Setzt du AI-Tools ein, die direkt oder indirekt Endkunden in**

der EU erreichen? ** Wenn ja → *mindestens Transparenz-Pflichten*

1. **Trifft deine AI Entscheidungen mit rechtlicher Wirkung oder

in den Bereichen HR, Finance, Healthcare, Bildung oder kritische Infrastruktur? ** Wenn ja → *High-Risk-Pflichten*

1. **Hast du dokumentiert, welche AI-Systeme du wo einsetzt, mit

welchen Daten sie trainiert/genutzt werden und wer dafür verantwortlich ist? ** Wenn nein → *AI-Inventar als erster Schritt nötig*

Für eine belastbare Einschätzung im Einzelfall: Datenschutz- und Compliance-Berater hinzuziehen.

Wie AEVUM hilft

AEVUM ist ein Operating-System für Unternehmen, das AI-gestützte Workflows einführt – von Anfang an Compliance-konform. Wir bauen Audit, Implementierung und laufenden Betrieb so auf, dass DSGVO- und AI-Act-Anforderungen integriert sind, nicht nachgerüstet.

Konkreter nächster Schritt: **AEVUM-Audit buchen** unter aevum-system.de/#/audit. Wir gehen deinen aktuellen AI-Einsatz durch und zeigen, welche Lücken geschlossen werden müssen.

Anhang: Verweis-Quellen

- **Offizieller EU AI Act-Text** – Verordnung (EU) 2024/1689,

EUR-Lex (eur-lex.europa.eu).

- **EU-Kommission AI Act-Übersicht** – digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai.
- **BSI (Bundesamt für Sicherheit in der Informationstechnik)** –

Leitfaden zu sicheren AI-Systemen.

- **AlgorithmWatch** – algorithmwatch.org (NGO, kritische

Begleitung von AI-Regulierung).

- **Bitkom AI Act-FAQ** – Praxis-Hinweise des Branchenverbands für

deutsche Unternehmen.

Erstellt: 2026-05-24 · AEVUM · Branchenneutral DACH

Diese Checkliste ersetzt keine Rechtsberatung. Für die konkrete Anwendung auf dein Unternehmen konsultiere Datenschutz-, IT-Recht- oder Compliance-Experten. Stand der Informationen: Mai 2026.